Monthly Intelligence Dispatch

June 2019

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specialises in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB reported that hackers from Silence stole about $3 million from a Bangladeshi bank.
- Western state-sponsored hackers breached the systems of the Russian tech giant Yandex in 2018 using Regin malware.
- Hackers breached NASA's network and stole about 500MB of data from 23 files, which were related to the Mars Science Laboratory mission.
- Group-IB observed new mass phishing emails containing Troldesh (Shade) ransomware.
- Turla, an APT group, is using the infrastructure of another APT, the Iran-linked OilRig group.
- Silence imitators have been detected. The mail servers they used for their emails were configured in a similar way.
- Sombra, a new tool for targeted attacks, appeared on underground forums. It is primarily intended for information collection.

Silence

Silence, a Russian-speaking cybercriminal group is likely to be behind the brazen attack on Dutch-Bangla Bank's ATMs resulting in the theft of $3 million. This is one of Silence's most recent international attacks, which indicates that the gang has expanded its geography and has gone global, focusing now on APAC markets.

On the CCTV footage posted by local newspapers two Ukrainian mules with their faces covered are seen withdrawing money from Dutch-Bangla Bank's ATMs on 31 May 2019. They made phone calls each time before withdrawing money, which immediately sparked Group-IB's Threat intelligence team's interest and indicated that the mules may have likely been involved in an organised financially-motivated cybercriminal group. At the time, Group-IB's Threat Intelligence team was already aware that Silence had been carrying out operations in Asia.

Information gathered by Group-IB's Threat Intelligence team coupled with their comprehensive knowledge about Silence's infrastructure suggests that Dutch-Bangla Bank's hosts have been communicating with Silence's C&C since at least February 2019. During the Dutch-Bangla Bank attack, the cybercriminals likely used the following Trojans: Silence.Downloader (also known as TrueBot), Silence.MainModule, which enables a threat actor to execute remote commands covertly and download files from a compromised server, and Silence.ProxyBot, which executes the tasks of a proxy server and allows an attacker to redirect traffic from a hidden node to a backconnect server via a compromised PC.

Once they gained access to the bank's infrastructure, Silence went on to the next stage of the attack — money withdrawal. The hackers could have either compromised the bank's card processing system or used the custom Atmosphere software.

Group-IB has been tracking Silence and its infrastructure since 2016. In September 2018, Group-IB published *Silence: Moving into the darkside*, the first report to describe the group's tactics and toolset in detail.

Major events: espionage, sabotage, leaks

APT33	The US Cyber Command has warned that the Iranian state-sponsored APT33 (Elfin) exploits an Outlook vulnerability that **Microsoft** patched as early as 2017. The vulnerability, which was discovered by researchers at **SensePost**, allows a threat actor to run malicious code on the underlying operating system. By 2018 it had been weaponised by APT33 and in late December 2018 the hackers installed backdoors on web servers, which they later used to push their exploit to users' inboxes and infect their systems with malware.
APT32	Another state-sponsored group called APT32 (also known as OceanLotus, CobaltKitty), which is based in Vietnam, uses a previously unknown tool called RAT Ratsnif, **Blackberry Cylance** reports. The program is capable of packet sniffing, ARP poisoning, DNS and MAC spoofing, HTTP redirection and injection, SSL hijacking, and setting up remote shell access.
NASA	A report by the NASA Office of Inspector General revealed that in April 2018 hackers breached NASA's network and stole about 500MB of data from 23 files. Two of them contained International Traffic in Arms Regulations information related to the Mars Science Laboratory mission. The point of entry was a Raspberry Pi device that was connected to the IT network of NASA's Jet Propulsion Laboratory (JPL) without authorisation. The hackers used this point of entry to move deeper inside the JPL network by hacking a shared network gateway. As a result, the attackers obtained information related to NASA's Mars missions.

Regin

Reuters reported that Western state-sponsored hackers breached the systems of the Russian tech giant **Yandex** in 2018 using a new variant of the Regin malware.

The Regin malware has been around since at least 2008, with most Regin infections observed in Russia (28%) and Saudi Arabia (24%), and other attacks spotted in Iran, Ireland, India, Afghanistan, Austria, Belgium, Mexico, and Pakistan. The consequences of Regin attacks were usually discovered when the infrastructure had already been completely compromised. The fact that Yandex managed to detect the attack in a few weeks' time shows that the company's cybersecurity level is very good.

The mere appearance of Regin-linked malicious code on the web does not necessarily mean that the attackers achieved their goals. After gaining initial access, the attackers would have to ensure persistence in the system, scan the infrastructure, find systems and data they were interested in, obtain privileges, take control over the systems, and then ensure that the data they needed were transferred outside the targeted systems covertly. In large organisations with complex infrastructure this can take months.

The fact that the attack was detected only a few weeks after it started suggests that this was only the first stage and it is unlikely that the attackers obtained what they were looking for.

Major events: espionage, sabotage, leaks

Ransomware

Two US cities in Florida, **Riviera Beach** and **Lake City**, fell victim to a ransomware attack. The city authorities decided to pay the hackers the ransom they demanded. The infection in Riviera Beach started after a police department employee opened an email with a malicious attachment and unleashed the ransomware on the city's network, which resulted in a shutdown of the city's website and services. Since the authorities were unable to get rid of the virus and the data the hackers encrypted had not been backed up, the authorities agreed to pay the attackers 65 Bitcoin ($600,000). In Lake City, the malicious email was opened by an IT employee. The ransomware spread across all of the city's computer systems and paralysed city services for two weeks. The authorities paid 42 Bitcoin ($500,000) in ransom to decrypt the city's systems.

Backdoor

Group-IB specialists discovered mass emails that resulted in the ServHelper backdoor being installed on victim machines. The attack affected organisations in Asia, Europe, and Africa. We should note that in December 2018 we observed a similar campaign that distributed the Servhelper backdoor. At the time, the list of targeted regions was the same: Asia, Europe, and Africa.

Turla

Turla, an APT group is using the infrastructure of another APT, the Iran-linked OilRig group. Turla (also known as Snake and Uroburos) has been active since at least 2007 attacking government organisations and private businesses. The list of known victims includes the Swiss defence firm RUAG, the US Department of State, and the US Central Command. Symantec experts say the hackers have recently started using a previously unseen backdoor called **Neptun** (Backdoor.Whisperer). One of the hackers' attacks involved the infrastructure of another espionage group called Crambus (also known as OilRig and APT34).

Troldesh

In June 2019, Group-IB observed new large-scale attacks with Troldesh (Shade) ransomware on Russian companies. The threat actors send emails purporting to be from the employees of major airlines, car dealerships and media outlets. Group-IB detected over 1,100 phishing emails containing Troldesh in June only. Q2 2019 saw a total of more than 6,000 such emails. At the moment, the ransomware campaign is still active.

Troldesh (also known as Shade, XTBL, Trojan.Encoder.858, Da Vinci, and No_more_ransome) is a virus that encrypts files on an infected device and demands a ransom for restoring access to that information. Its command and control centre is based in the Tor network and always changes its location, which makes it hard to block and increases the probability of infection. Troldesh is sold and rented out on special platforms on the Darknet, which is why the virus constantly acquires new features and changes distribution methods. The latest Troldesh campaigns showed that in addition to encrypting files, the ransomware can now mine cryptocurrency and generate website traffic to increase the number of visits and the revenue from online ads. According to Threat Detection System (TDS) data, the scale of Troldesh attacks in Q2 2019 is almost 2.5 times bigger than the figure for the whole of 2018.

Group-IB first detected Troldesh activity in 2015. The specialists noted that the virus successfully bypassed antivirus software. Threat actors regularly changed the packer, a compression program that reduces file size and makes detection and reverse engineering more difficult, which is why antivirus software often failed to detect it. By the end of 2018, Troldesh had become one of the most popular ransomware programs sharing the top-3 list with RTM and Pony. Experts at PaloAlto Networks report that Russia is not the only country Troldesh is active in, with other victims located in the US, Japan, India, Thailand, and Canada.

Pseudo-Silence

Silence imitators have been detected. Group-IB examined some of the summer email campaigns believed to have been carried out by Silence and established that the emails were not linked to the group. The mail servers in the campaigns were configured in a similar way and were deployed using Interspire, MailWizz, Mumara, or PowerMTA. The emails contained links to phishing pages or malware loaders with no relation to banking Trojans. This is not characteristic of Silence, which engages in targeted attacks on banks and uses unique tools for their attacks.

Riltok

Riltok, a banking Trojan that initially attacked customers of Russian banks, has been adapted for the European market, **Kaspersky Lab** reports. The malware was discovered in March 2018: the Trojan was disguised as popular free advertising services. In late 2018 Riltok went international. In November 2018, a version of the Trojan for the English market appeared in the shape of Gumtree.apk. Italian (Subito.apk) and French (Leboncoin.apk) versions appeared shortly afterwards in January 2019. The threat actors kept the same masking and distribution methods, using names and icons imitating those of popular free ad services. At the moment, most of the victims (90%) are in Russia, with France being second (4%). Italy, Ukraine and the UK are third.

MajikPos

In late May 2019, Group-IB specialists detected and examined the loader of the MajikPos malware and obtained the loader's payload, which is MajikPos. MajikPos is a malicious program designed for attacks on POS terminals. The malware was discovered in 2017, when it was used in attacks mostly in the US and Canada. The threat actors scanned systems for poorly protected open VNC and RDP ports to gain unauthorised access to POS terminals. Once such terminals were discovered, the threat actors launched brute-force attacks to penetrate a targeted system. MajikPos was usually loaded using VNC, RDP, FTP, and AmmyyAdmin protocols, or RATs previously installed in the system. The malware collected information about each victim and used modules for scanning local computers that contained financial data. When the malware found workstations with POS data, it loaded Memory Scraper, a module that scans device memory to steal payment card data from the workstations' RAM. The malware is designed for stealing data from POS terminals and enables threat actors to compromise bank card magnetic stripe data (Track 1 + Track 2). Group-IB specialists established that the campaign that the detected samples were linked to mostly affected Brazil and France. Most of the compromised bank cards were issued by South American banks ITAU UNIBANCO, BANCO DO BRASIL, BANCO SANTANDER BRASIL, and BANCO BRADESCO. The campaign is still active and newly detected compromised cards are added to Intelligence.

Cobalt

Group-IB discovered indicators of a Cobalt email campaign that was carried out in April 2019. The attack involved a JS backdoor being installed on the victim's machine.

BLACKSPIDER

On 13 May 2019, the first set of dumps called BLACKSPIDER was put up for sale on **Joker's Stash**, an underground marketplace for selling compromised bank cards. In early June 2019, 16 databases from the BLACKSPIDER leak were posted, with 78,016 cards available. The number of cards, the sale of magnetic stripe data (the dumps) without PIN codes, and the fact that the cards' breakdown by banks is relatively even suggest that the source of the compromise was a network of trojanised POS terminals. Group-IB specialists' analysis of the bank cards from the BLACKSPIDER leak revealed that the compromised cards may have been used in **Cotton Patch Cafe**, a US restaurant chain. The threat actors are believed to have trojanised POS terminals in 14 locations. It was revealed that each of the four US states Cotton Patch Cafe has restaurants in had crossovers with the locations from the leak.

Bitrue	Bitrue, a Singaporean exchange, had 9.3 million Ripple (XPR) and 2.5 million Cardano (ADA) tokens stolen, worth overall $4.5 million. An investigation revealed that the attack affected about 90 Bitrue users. The trading activity was suspended immediately after the incident. This is a second attack on the exchange this year: in January 2019 Bitrue suffered a 51% attack, in which threat actors attempted to steal 13,000 Ethereum Classic (ETC) tokens worth $100,000. The attack, however, was thwarted.

Major events: malware

Sombra

A new tool for targeted attacks called Sombra has been put up for sale on Exploit, an underground forum. The tool is an equivalent of Meterpreter and is a multifunctional payload that can be extended during execution. The author of the post is a user named **APTeam**. The seller mentioned that the tool was designed for targeted attacks and that they were seeking cooperation with an APT group. The author also wrote, however, that the tool lacked comprehensive solutions for bypassing antivirus software, which is why the malware is primarily intended for information collection rather than active attacks. An exclusive partnership costs $100,000 per month. If no partners are found, the malware will be rented out with a limited number of licences at $3,500 per month. There are doubts, however, that the tool actually exists, since the product does not have any reviews and the seller has not undergone any checks, publishing the post only a couple of days after they registered.

Arrests and sentences

Typosquatting

Six people have been arrested in the UK and the Netherlands on suspicion of stealing account data of cryptocurrency wallets. The arrests are a result of a joint operation conducted by the Dutch police, Europol, Eurojust, and the UK's National Crime Agency. The investigation lasted for over a year. More than 4,000 people from 12 countries are thought to have fallen victim to the fraudsters, with €24 million worth of cryptocurrency stolen. The threat actors carried out phishing attacks against cryptocurrency holders or registered fake websites with domain names very similar to the names of well-known cryptocurrency services. Once users entered their login credentials, the information was obtained by the attackers.

Petko Petrov

The Bulgarian police detained Petko Petrov, an IT expert, for 24 hours after he publicly demonstrated the exploitation of a vulnerability in software used by local kindergartens. Petrov exploited the flaw to download the details of 235,543 citizens of Stara Zagora, a province in central Bulgaria with over 333,000 inhabitants, and published a PoC video on Facebook. Petrov decided to publicly disclose the vulnerability after he attempted, without success, to report it to the company that had developed the software.

Forecasts and warnings

- New attacks by Silence can be expected in the APAC region. Their imitators are likely to be active in Russia and the CIS.
- The list of victims of state-sponsored hackers that use the Regin malware may be quite extensive. The malware is difficult to detect and many organisations learn about being a Regin attack victim only after their infrastructure has been completely compromised.
- The new tool for targeted attacks called Sombra is likely to be used for information collection purposes.
- Vishing, a type of phone fraud, will remain the most popular method of stealing bank card data. It accounts for over 80% of all thefts of money. In 2018, the number of recorded instances of fraud that occurred via the phone in Russia was 42,712.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organisation.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com